

Define your target device/firmware

I have chosen Wyze Cam V3. I chose this device because I found it has vulnerabilities and

I saw a few videos; people can flash this V3 version, and it is a Linux-based device.

However, it was not the pan camera.

Please confirm that this device is a good choice to explore.



I have already opened the camera and am trying to identify components.



If I find it is difficult to explore

Discuss your initial plan for how you are going to audit this device and the type of bugs you anticipate finding.

My first goal is to read the software from the camera itself by attaching USB to UART device, I need some guidance here.

If I am not successful as a backup, I have git GitHub repo for the firmware.

<https://github.com/kohrar/Wyze-Firmwares>

https://github.com/gtxaspec/wz_mini_hacks/discussions/732

I want to do two things

- 1- Authentication bypass.
- 2- Gain root Access

Did research and found that Wyze Cam V3 firmware includes the following vulnerabilities.

Authentication bypass: Allows attackers to bypass the account log-in process and access users' cameras.

Remote code execution flaws: These flaws enable attackers to run their own software code on vulnerable cameras.

Unauthorized access to SD card contents: This permits unauthenticated access to videos and images stored on local memory cards.

Specific vulnerabilities identified by Bitdefender in the ThroughTek Kalay (TUTK) communication framework:

CVE-2023-6322: Allows an attacker to gain root access through a stack-based buffer overflow in a handler for a specific IOCTL message.

CVE-2023-6323: Enables a local attacker to leak the AuthKey secret by impersonating the P2P cloud server.

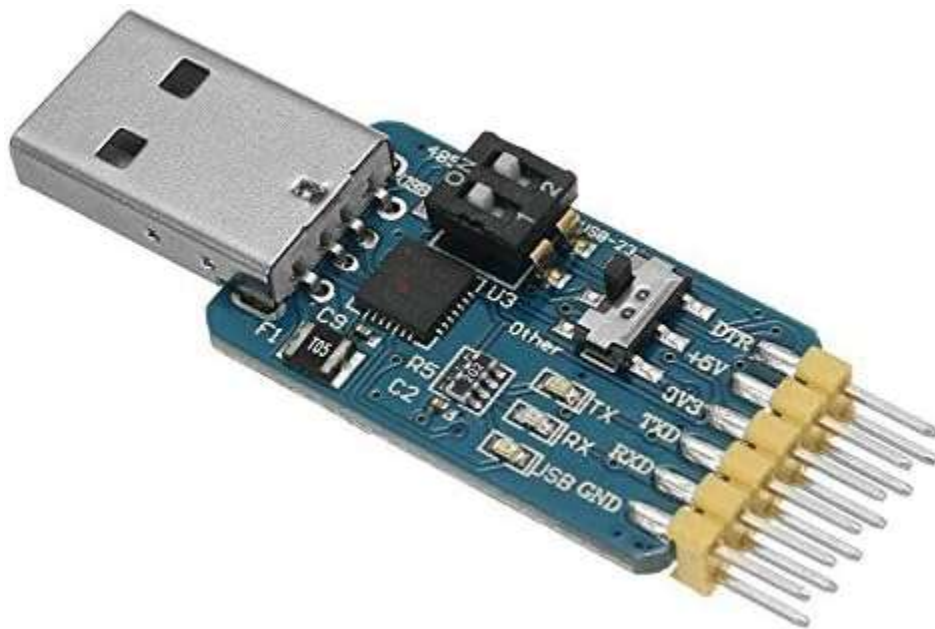
CVE-2023-6324: Allows a local attacker to infer the pre-shared key for a DTLS session by forcing an empty buffer.

CVE-2024-6247: Allows physically present attackers to execute arbitrary code during the camera setup process by exploiting a vulnerability related to the handling of SSIDs embedded in scanned QR codes.

CVE-2024-6248: Allows network-adjacent attackers to execute arbitrary code by exploiting an improper authentication vulnerability in the cloud infrastructure that uses the device's MAC address as a sole credential.

Option a - discuss how you plan to extract the firmware. Option b - discuss how you plan to use virtualization/emulation

I think USB to UART device can be helpful. If I can identify TXD and RXD ports on the camera. Still researching what software I need to use thereafter. Either directly getting firmware from the device or from github. Once the firmware is accessed, planning to use tools such as binwalk, as mentioned in the lecture and ghidra or any recommended tools can be used to gain further information about the firmware and the code being used by the device



Define your overall research objectives

My research objective is to identify and validate at least one of the vulnerabilities identified by Bitdefender CVE-2023-6322 for this firmware

Here is my home lab picture. I also acquired a TP-Link switch as a backup device to explore.

